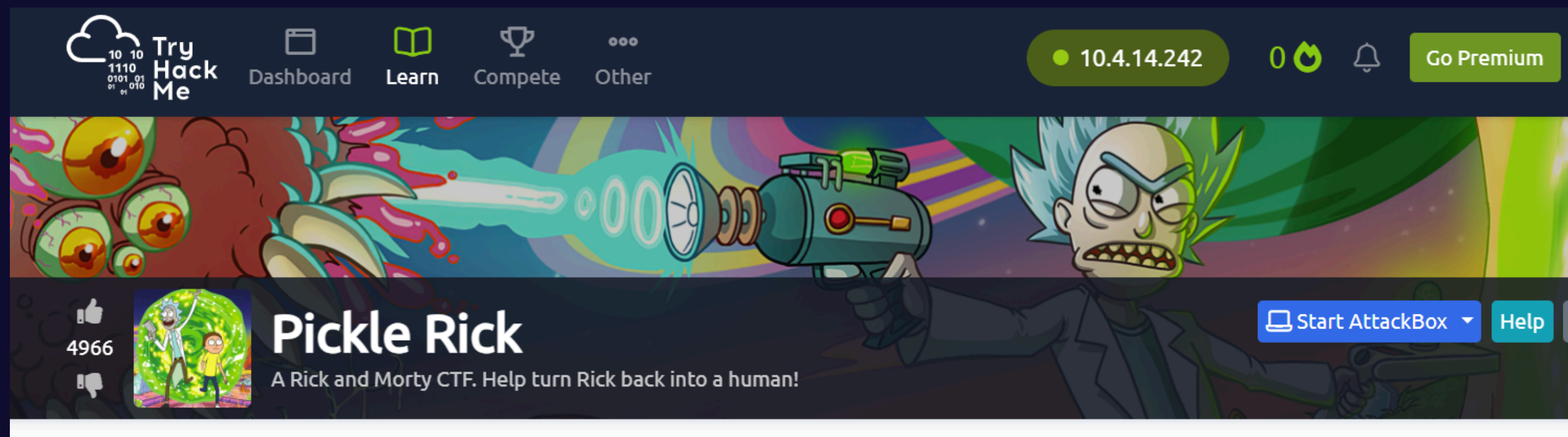


Trabalho de reconhecimento

Leonardo Esteves, Lorenzo Meyer, Pedro
Webber.

Escopo

O nosso alvo para o reconhecimento foi o CTF “Pickle Rick” da plataforma TryHackMe.



Ref: <https://tryhackme.com/room/picklerick>

Nmap

Rodamos o Nmap para identificar portas abertas e serviços ativos no nosso alvo, e identificamos os seguintes serviços e portas rodando:

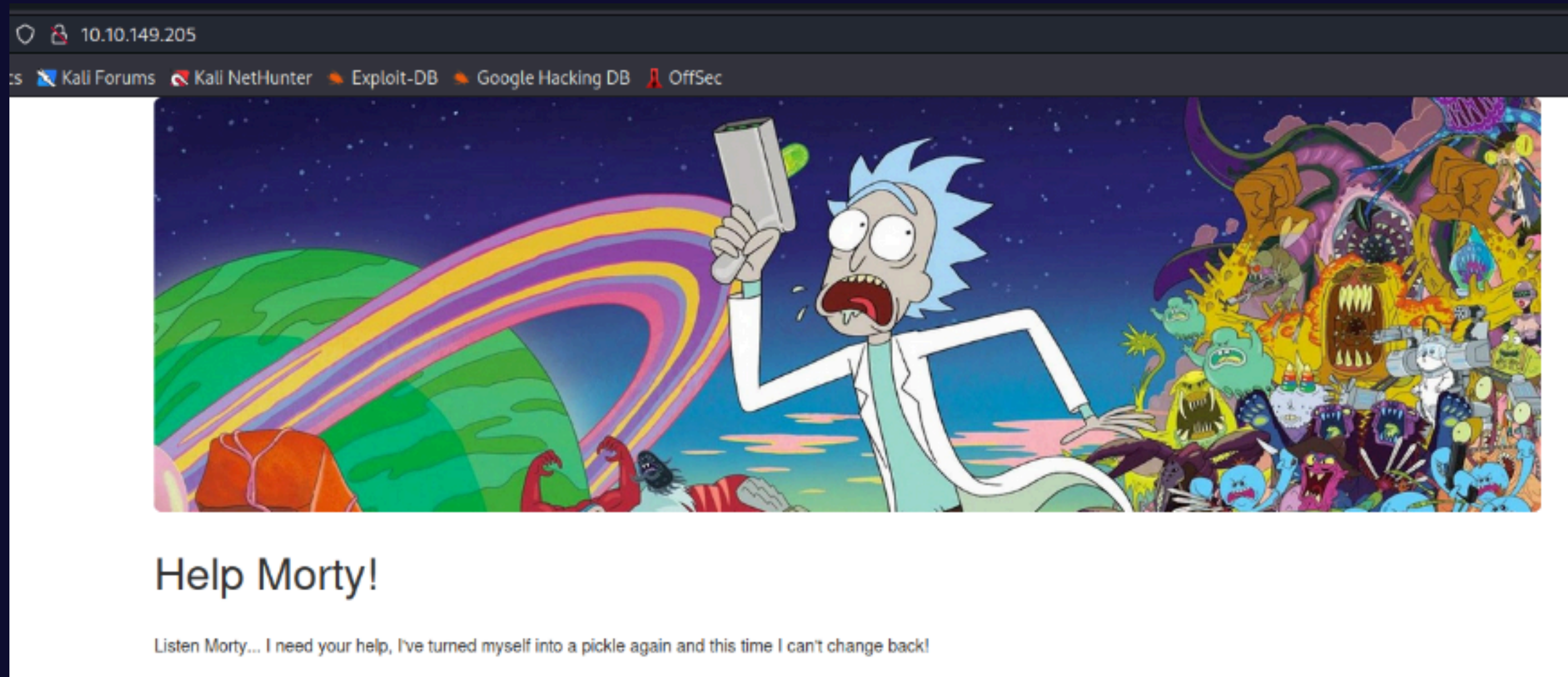
```
Some closed ports may be reported as filtered due to: default-13c-14cc1m1c
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.2p2 Ubuntu 4ubuntu2.6 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.18 ((Ubuntu))
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Comando Nmap utilizado:

```
nmap -sV -Pn --open -p- 10.10.149.205
```

HTTP

Ao acessar a porta 80 (padrão HTTP web),
identificamos um site rodando:



No site, não havia nada além de frases escritas,
a única possibilidade, seria visualizar o código fonte da página.

HTTP

Código fonte

Foi encontrado no código fonte da página, um comentário com um nome de usuário:

```
24     <p>I need you to <b>*BURRRP*</b>....Morty, logon to my computer and find the last three secret ingredient
25     I have no idea what the <b>*BURRRRRRRRP*</b>, password was! Help Morty, Help!</p><u><br>
26 </div>
27
28 <!--
29
30     Note to self, remember username!
31
32     Username: RickRu13s
33
34 -->
35
36 </body>
```


Dirsearch

Após se esgotar as possibilidades no index principal, usamos o Dirsearch para enumerar os diretórios e arquivos do site.

Resultados encontrados:

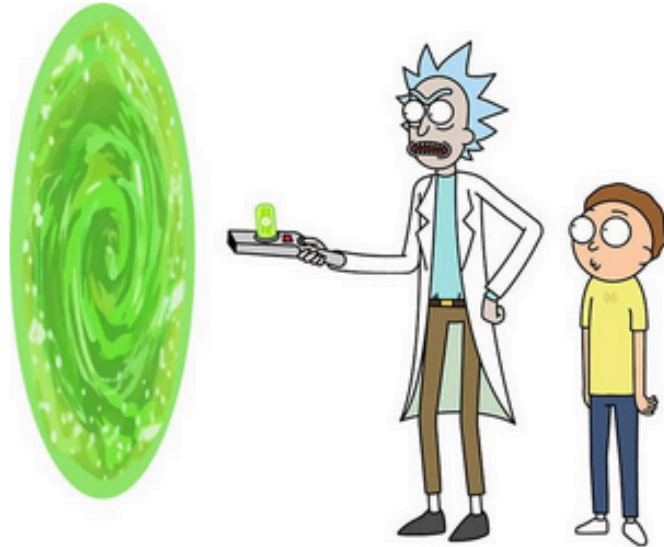
```
SecLists / Discovery / Web-Content / Common-PHP-FileNames.txt
[11:07:31] Starting:
[11:07:39] 200 - 882B - /login.php
[11:07:55] 302 - 0B - /portal.php → /login.php
```

Como também, o arquivo /robots.txt, que é padrão de todo site web.

Arquivos

/login.php

No arquivo /login.php, encontrado na execução do Dirsearch, existe uma tela de login:



Portal Login Page

Username:

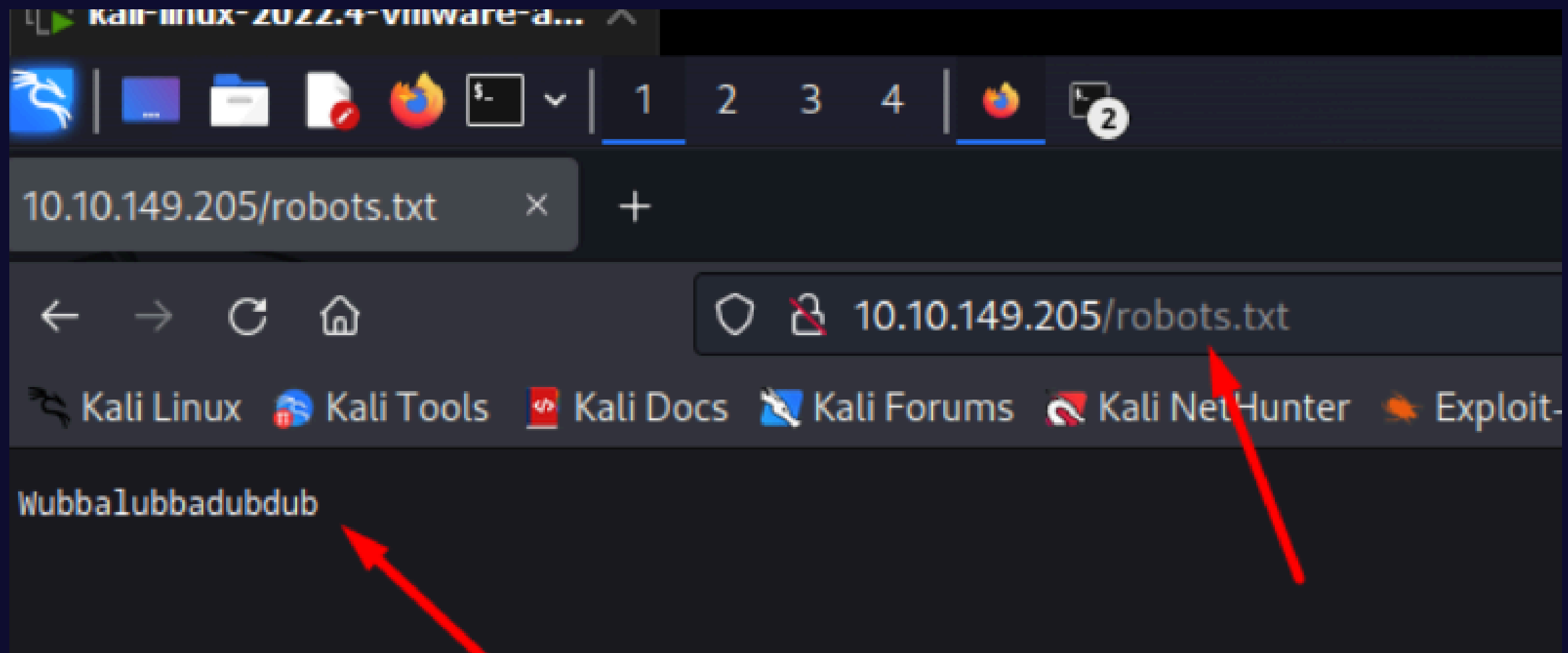
Password:

Login

Arquivos

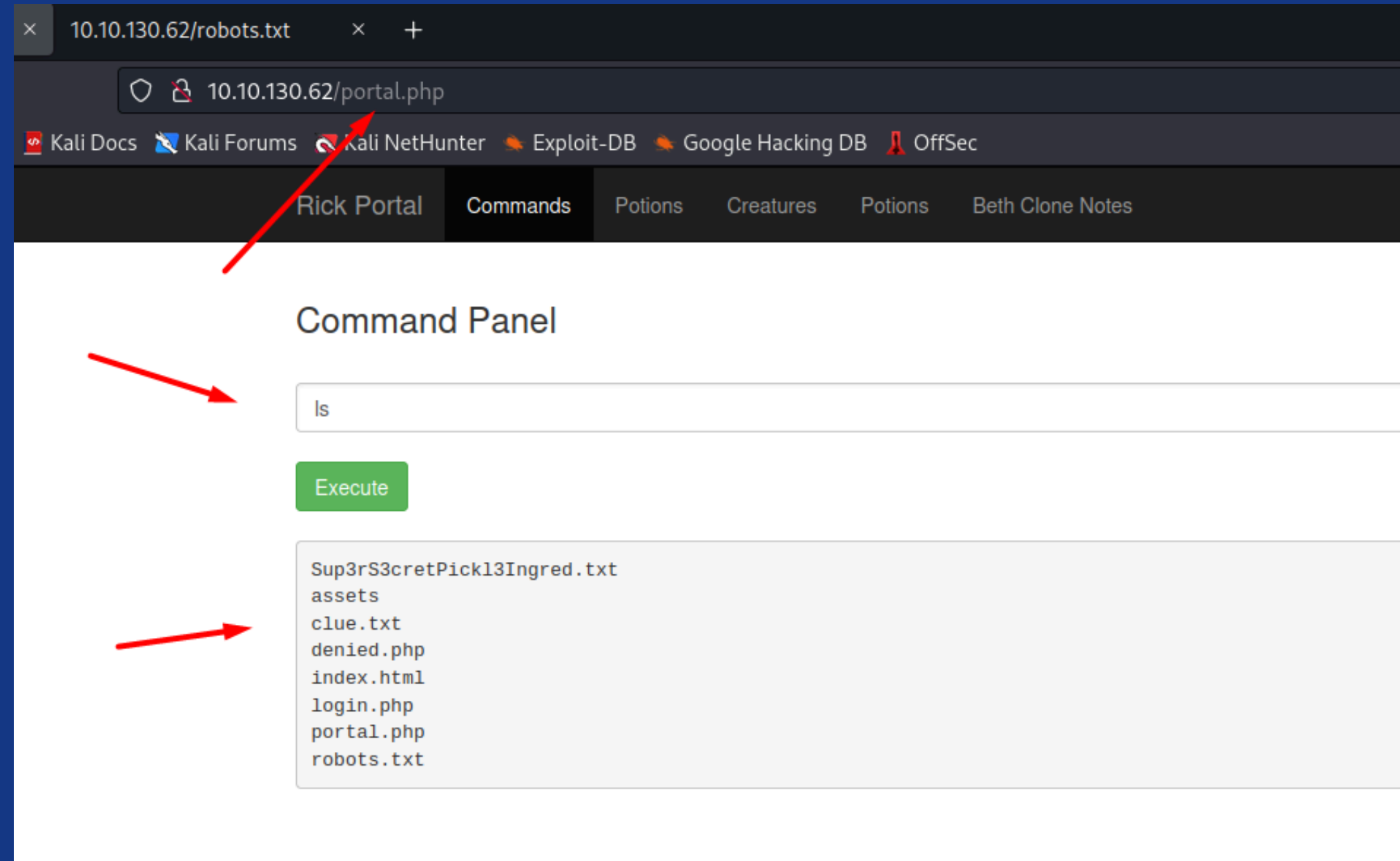
/robots.txt

No arquivo /robots.txt, foi encontrada uma frase sem sentido:



Login

Com o nome de usuário que encontramos no index, e esta frase sem sentido no arquivo /robots.txt, podemos tentar efetuar login na aplicação.



Login

Observe que, ao se autenticar, ele utiliza o arquivo /portal.php, que é o outro arquivo encontrado no Dirsearch.

Após autenticar, havia um campo que permitia execução de comandos (não administrativo) no servidor.

A partir daqui é necessário escalar privilégios para ter controle administrativo total do servidor.

